

[대외비] (주)온다로지스 수탁자 현황 자료

1. 수탁자 기본 현황

- 회사명: (주)온다 로지스 (ONDA Logistics Inc.)
- 대표자: 임희동
- 설립일: 2022년 3월 10일
- 소재지: 서울시 중구
- 직원 수: 총 250명 (경영지원 20명, IT지원 10명, 지상조업/물류 현장직 150명, 배송기사 70명)
- 주요 사업: 항공 화물 지상 조업, 물류 센터 운영, 화물 라스트마일(Last-mile) 배송 대행

2. 개인정보 위탁 업무 내역

- 위탁자: (주)하랑항공 (위탁 담당부서: 항공화물운송팀)
- 위탁 업무: 하랑항공 항공화물 운송·배송 물류 위탁 운영 일체
- WMS(물류 관리 시스템) 기반 출고, 피킹, 검수, 배차 및 최종 배송 확인
- 물류 터미널 내 현장 공용 PC 및 PDA(산업용 단말) 기반 화물 스캔 및 상태 조회
- 위탁사(하랑항공) B2B 연동(API 등) 기반 화물 접수 데이터 처리 및 결과 회신
- 수하물 분실, 파손, 지연에 따른 예외 보상 및 클레임 고객 대응
- 계약 기간: 2025년 2월 1일 ~ 2026년 2월 1일 (1년, 연간 자동 갱신 조항 포함)
- 개인정보 재위탁 현황
 - 물량 폭주 및 지방 배송을 위해 지역 하역사 및 지입차주에게 하역/배송 업무 재위탁

3. 처리하는 개인정보 항목 및 규모

- 데이터 접근 방식
 - (A) 위탁사 연동 API: 전용 VPN 터널링을 통해 하랑항공 B2B API와 연동하여 운송 수행에 필요한 필수 화물 정보 수신
 - (B) 수탁자 자체 시스템: 수신된 화물 정보를 바탕으로 온다로지스 자체 WMS(물류관리시스템) 서버 및 레거시 창고 물류 DB에 저장 및 처리
- (A) 위탁사 연동 수신 항목 (접근·조회)
 - 수취인(화주) 성명, 연락처, 배송지 주소

- 운송장 번호, 화물 및 수하물 예약 번호
- 여권번호 및 계좌번호 (원칙적으로 고유식별정보는 미처리하나, 분실·파손 보상, 보험, 특수 화물 처리 등 예외 업무 발생 시 일시 수집)
- 규모: 하랑항공 전체 연간 약 500만 건 정보주체 처리 대상 보유
- (B) 수탁자 자체 DB 및 로컬 저장 항목
 - 수취인 성명, 연락처, 주소, 운송장 번호 (배송 관리를 위해 WMS 저장)
 - 규모: 배송 완료 후 5일 경과 데이터 자동 파기 배치 적용 중
 - ※ 참고 물류 레거시 프로그램 DB 내 사용자 비밀번호가 해킹에 취약한 구형 암호화 알고리즘(MD5, SHA-1)으로 저장됨
 - ※ 업무용 PC 로컬 바탕화면 및 부서 공용 NAS(공유폴더)에 수취인 정보가 담긴 수백 건의 엑셀 고객 명단이 문서 자체 암호화 없이 평문으로 방치됨

4. 개인정보 처리 시스템 현황 (논리적 망분리 환경)

- 시스템 구성
 - 서버 환경: WMS 운영 서버, API 게이트웨이, 레거시 스캐닝 DB 서버 등은 본사 사내 서버실(On-premise)에서 운영 중
 - 현장 환경: 물류 인도장, 도크, 출고 데스크 등에 업무용 공용 PC와 현장 작업자용 다수의 공용 PDA 단말기 비치 및 운영
 - 단말기: 현장 공용 PDA에 단일 계정('admin/1234')을 포스트잇으로 붙여 공유하고 있으며, 화면 대기시간이 60분으로 과도하게 설정되어 보안에 취약함
- 네트워크 (논리적 망분리)
 - VLAN 기반의 논리적 망분리 형태로 내부 업무망과 외부 인터넷망을 분리하여 운영 중
 - 망분리 우회: 현장 관리자 단말기 등에서 가상화(VDI) 우회 등을 통해 인터넷망과 내부 업무망(WMS)에 동시 접속 가능한 구조적 결함이 있으며, 망 간 클립보드 복사 차단이 해제되어 있음
 - 유출 통제: 현장 업무 편의를 명목으로 방화벽 정책에서 개인 웹하드 및 개인 이메일 접속을 일괄 예외 허용하여, 망분리 취약점과 연계된 외부 파일 유출 경로가 활짝 개방되어 있음
 - 무선망: 업무용 PDA 연결을 위한 무선 AP망은 WPA3 암호화가 적용되어 양호하나, 비인가 불법 테더링 접속을 차단할 무선침입방지시스템(WIPS)이 부재함

5. (자체 점검) 보안 관리 현황

5.1 내부 관리 계획 및 조직

- 내부관리계획서 존재, 재위탁 통제, 현장 단말기 물리적 안전조치가 부재, 1년간 정기 검토 및 최고경영책임자 승인 이력이 없음
- 정책문서는 그룹웨어로 공지되고 있으나 현장 작업자 대상 오프라인 공표물과 체계적 미전파
- 침해사고 대응절차와 위탁사 통보 체계는 있으나, 비상연락망 일부 현행화 미흡과 현장 초동조치 체크리스트 부재
- 백업 및 복구 계획은 존재. 무선 AP 장애, PDA 파손 등 물류 현장 중심의 업무연속성 대체 절차와 현장 연계 훈련 부재
- CPO 지정, 역할 문서화, 전담조직 구성 운영
- 개인정보취급자 명단 관리 진행, 재위탁 인력 명단 최신화가 지연되어 실제 투입 인력과 관리대장 간 내용 불일치
- 내·외부 인력 보안서약서는 징구·보관되고 있음
- 정기 교육, 신규자 교육, 재위탁 인력 교육에 대한 증적 부재

5.2 접근 통제 및 권한 관리

- 개인별 계정 원칙은 운영되나 현장 공용 PC와 일부 보조 조회용 계정 사용
- 권한이 직무별로 구분 미흡
- 계정 발급은 그룹웨어 전자결재를 통해 승인 후 처리
- 내근직은 퇴사 당일 권한이 회수됨, 현장 인력은 행정 지연으로 퇴사 후에도 계정이 일정 기간 활성 상태로 남는 사례 존재
- 권한 변경 이력은 남고 있으나 일부 로그 보존기간이 법정 기준에 미달
- 현장 PDA에서 공용 계정과 단순 비밀번호가 공유
- 사무용 단말은 세션 타임아웃이 적절하나 현장 PDA는 세션 대기 시간이 60분
- 일부 레거시 시스템은 로그인 실패 제한 미적용

5.3 접속기록 보관 및 점검

- 접속 로그 자동 생성 기능 비활성화 및 로그 기록 항목 부재
- 정기 점검은 형식적 수동 보고 수준, 이상행위 탐지 기준과 자동 알림 체계가 부재
- 일부 모바일·PDA 구간 로그 보존기간이 법정 기준에 미달
- 로그 위·변조 방지와 격리 백업 체계 구축

5.4 비밀번호 관리

- 비밀번호 복잡도, 재사용 금지 등 정책 규정 부재
- AD 서버 및 WMS 시스템 내비밀번호 생성 단계에서 비밀번호 복잡도 필터링 부재
- 비밀번호 갱신 이력 부재
- 사무용 PC가 화면 자동 잠금이 강제로 적용되며, 잠금 해제 시 패스워드 입력 요구 프롬프트 활성화
- 현장 기기 관리 정책에서 단말 자동 잠금 기능은 활성화되어 있으나, 현장 작업자가 업무 상 편의 사유로 잠금화면 대기 시간을 1시간으로 설정

5.5 접속 보안 및 네트워크

- 내부망 내 개인정보처리시스템 외부 접근 시 방화벽 차단/허용 정책 존재
- 재택 근무로 접속 시 안전한 접속 수단 의무화 정책 존재
- 외부 접속 시 추가 인증 적용
- 침입방지시스템 운영 현황 및 시그니처 정기 업데이트 점검 진행
- 논리적 망분리 아키텍처는 미구축
- 무선랜 신청/승인 이력관리대장 작성
- 동일 단말기에서 내/외부망 동시 접속 차단 부재
- 중요단말기 식별 및 비업무/유행사이트 접근 차단 솔루션 정책적 차단 부재
- 작업자가 임의로 화면 캡처 툴, 압축 프로그램 등 비인가 SW를 다수 설치

5.6 단말기 보안

- 고객용 웹페이지를 통해 여권번호 등을 수집 중이나, 법정 필수 의무인 연 1회 정기 취약점 점검(모의해킹) 및 개선 증빙이 부재
- 핵심 서버 전체에 백신 설치 및 실시간 감시가 활성화되어 있으며, 업데이트 실패 시 관리자 알람 등 중앙 관리 체계가 정상 가동
- 직접 검증 결과 최신 보안 패치가 누락 없이 적용되어 있으며, EOS(기술지원 종료) 소프트웨어 없이 주기적인 모니터링과 업데이트를 이행
- PC 기본 공유 폴더 개방, NAS 내 익명 접근 허용, 개인정보 파일 암호 미설정 전사 PC 보안 솔루션 설치 및 실시간 감시가 강제화
- WSUS 및 PMS를 통해 OS와 서드파티 응용프로그램 패치를 중앙에서 자동 배포
- DLP를 통한 USB 쓰기 원천 차단, 사전 승인 절차 운영, 데이터 반출 로깅 및 물리적 자산 반출입 통제

5.7 개인정보 암호화 및 출력 통제

- WMS 본 서버에 비밀번호 평문 저장 및 레거시 시스템의 취약 알고리즘(MD5, SHA-1) 사용, 솔트(Salt) 적용 부재와 공용 계정('admin/1234') 사용
- DB 원장 저장 시 AES-256 알고리즘 적용은 적정하나, 시스템 진입 과정(WAS 에러 로그, DMZ 임시 폴더)에서 일시적으로 평문이 잔류하는 구간이 존재
- 외부 전송 시 파일 암호화 지침과 강제 통제 솔루션 부재로 대량의 배송 명단을 평문으로 이메일이나 메신저로 전송
- 전사 마스킹 표준 기준을 수립하고, WMS 화면 및 PDA 앱에서 성명, 연락처, 주소 등에 대한 마스킹 로직이 일관되게 적용
- '키 관리 대장'이 전무함. 키 교체(Rotation) 주기나 파기 절차 등 생명주기 관리 정책이 미수립
- 업무 PC 내 수백 건의 개인정보 파일이 평문으로 방치. DRM(문서보안) 등 자동 암호화 솔루션이 부재하고, 인터넷을 통한 외부 반출 경로가 개방
- 출력물 관리대장 미작성, 복합기 인증(사원증 태깅) 기능 미사용
- 대량의 지시서 반출 시 사전 승인 절차 부재

5.8 개인정보 생명주기

- API 연동 시 필수 정보만 수집하는 원칙은 수립되어 있으나, 콜센터 상담원이 예외 처리 과정에서 고객의 계좌번호나 추가 연락처를 사전 협의 없이 임의 수집하는 사례가 적발
- DB 아키텍처상 논리적 격리(스키마 분리)는 양호하나, 담당자 PC 내에서는 타 위탁사 데이터와 하랑항공 데이터가 동일 폴더에 혼재
- 위탁사(하랑항공)의 사전 서면 승인 없이 구두로 재위탁을 진행하는 프로세스 위반
- 업무 편의를 위해 타 택배사 등에 개인정보를 임의 제공하는 관행이 있으나, 법정 필수 문서인 '제3자 제공 관리대장' 양식조차 비치되지 않음. 책임자 승인 및 사후 모니터링 체계가 전면 부재
- 파기 지침은 존재하나 현장 PC에 수개월 치 배송 명단 엑셀 파일이 대량 방치
- 작업장 쓰기통에서 파쇄되지 않은 배송 지시서 원본이 다수 발견
- 수기 동의서 등 하드카피 서류가 일반 서류와 혼재 보관
- 기본적인 시스템 삭제는 수행 중이나, 와이핑 결과나 파쇄 사진 등 객관적 파기 증빙 자료 생성이 누락, 이에 따라 위탁사(하랑항공)에 정기적으로 파기 결과를 보고해야 하는 의무 이행 기록이 부재

6. 개인정보 재위탁 현황

- (주)한결하역: 하역 및 배송 업무
- 원위탁자(하랑항공)의 사전 서면 승인 없이 구두로 재위탁을 진행하여 위탁 계약 프로세스 및 절차 위반
- 야간 하역 등을 담당하는 하청업체 직원 대상 개인정보보호 교육이 전무하며, 교육 참석 대장 등의 관리 감독 증적 부재
- 잦은 인력 변동으로 인해 재위탁 인력 명단 업데이트가 평균 1~2주 지연되는 등 취급자 명단 현행화 미흡
- 인도장 창고 내 하청업체별 물리적 펜스 분리가 되어 있지 않아, 타 업체 직원이 화물 지시서 및 고객 정보에 무단 접근할 수 있는 통제 공백 존재
- 재위탁 인력에 의한 하드카피 서류(배송 지시서 등) 파기 시, 파쇄기를 거치지 않고 무단 투기하는 등 현장 파기 통제 미흡 및 파기 관리대장 작성 누락